

-



- [About TFB](#)
- PSD2 Compliance

On this page

PSD2 Compliance

Was this page helpful? 

Learn how Feedzai's TFB helps financial institutions to be compliant with the second Payment Services Directive, in particular with Transaction Risk Analysis, providing real-time recommendations for strong customer authentication.

Payment Services Directive

The Payment Services Directive (PSD) is an EU directive that regulates payments and payment service providers throughout the European Economic Area.

The second Payment Services Directive (PSD2) defines new rules to:

- Improve individuals protection in online payments.

- Promote the development and use of innovative online and mobile payments, such as open banking.
- Make cross-border European payment services safer.

To protect account holders, PSD2 mandates that e-commerce and bank transfer transactions must meet Strong Customer Authentication (SCA). Transaction Fraud for Banking (TFB) provides real-time recommendations to help issuers decide when to enforce SCA and when to safely exempt SCA.

Strong Customer Authentication

SCA is a method that requires individuals to prove their identity by providing two of the three authentication categories:

- **Knowledge:** Something only the user knows, e.g. a password or a PIN.
- **Possession:** Something only the user possesses, e.g. the card or an authentication code generating device.
- **Inherence:** Something the user is, e.g. the use of a fingerprint or voice recognition.

Note that not all transactions require SCA, i.e. there are out-of-scope conditions that exclude a transaction from PSD2. Additionally, to provide a better user experience especially for low-value and low-risk payments a set of exemptions can be normally applied. These exemptions may be requested upstream by the merchant, acquirer or network, or downstream by the issuer.

Out-of-scope criteria

Out-of-scope transactions include:

- **Interregional transactions:** Payments where the card was issued outside of Europe or where the country you are acquiring from is outside of Europe. Some European issuing banks are expected to require SCA, whether a payment is acquired outside of Europe or not.
- **Cash payment**
- **Payments using a physical card at a POS terminal:** This payment method is already secured via two-factor authentication (i.e. chip and PIN).
- **Merchant-Initiated Transactions (MIT) and Direct Debits:** A payment or a series of payments with fixed or variable amounts that the merchant performs without direct involvement of the shopper. Examples are subscriptions, automatic account top-ups, and installments. The initial transaction should have gone through SCA and the shopper should have agreed to the terms and conditions of the succeeding MITs.
- **Mail Order and Telephone Orders (MOTO):** MOTO transactions are not considered to be electronic payments, so these are out of the scope of the regulation.
- **Anonymous cards:** This type of cards can only be identified by the issuing bank. For example, anonymous prepaid cards.

Exemption criteria

For transactions that are in the scope of PSD2, the merchant or the PSP can request SCA exemption if the transaction meets any criteria in the following list. The issuer decides whether the exemption is granted. Additionally, the issuer can grant an exemption without the merchant or the PSP requesting it.

The exemptions that can be requested are the following:

- **Low Value:** Transactions under 30 euros do not require SCA, but the issuer will keep track of certain counters, such as the number of transactions or the sum of transaction amounts. If the account/card holder exceeds the counter, for example, after five consecutive transactions or if the sum exceeds 100 euros, the issuer will require SCA. This exemption is defined by the PSD2 **Article 16**.
- **Low Risk/Transaction Risk Analysis (TRA):** Issuing banks can consider transactions as low risk based on their average fraud levels, acquirer's fraud levels, or both. The market official measure for fraud level in the PSD2 scope is known as [Fraud Rate](#). This exemption is defined by the PSD2 **Article 18**. This exemption can occur in different ways:
 - **TRA exemption request from merchant or PSP:** The merchant can request the TRA exemption to the issuer if the merchant's fraud levels are below a safe threshold. If the exemption is granted, the chargeback liability stays with the merchant.
 - **TRA exemption from the issuer:** The issuer can exempt TRA even when the merchant or the acquirer does not request it. Sending additional information in the payment request can help to maximize the probability of getting this exemption. The chargeback liability shifts to the issuer.

- **Recurring transactions with exact same amount:** This exemption is expected to be overridden by MIT and might be considered as [out of scope](#). This exemption is defined by the PSD2 **Article 14**.
- **Whitelisted merchants or trusted beneficiaries:** After a strongly authenticated payment session, account/card holder can add the merchant to a whitelist for the issuer. The issuing bank will not require SCA on the next payments for the same merchant. However, note that this exemption depends on whether the issuer supports whitelisting. This exemption is defined by the PSD2 **article 13**.
- **Secure corporate payments:** These are payments made through dedicated corporate processes initiated by businesses and not available for an account/card holder. Examples are payments made through central travel accounts, lodged cards, virtual cards, and secure corporate cards, such as those used in a corporate travel management system. This exemption is defined by the PSD2 **Article 17**.
- **Unattended payment terminal for a parking fee:** Payment service providers are allowed to skip SCA when the payer initiates an electronic payment transaction at an unattended payment terminal for the purpose of paying a transport fare or a parking fee. This exemption is defined by the PSD2 **Article 12**.
- **Credit transfers between accounts held by the same natural or legal person:** Payment service providers shall not apply SCA if the payer initiates a credit transfer in circumstances where the payer and the payee are the same natural or legal person, and both payment accounts are held by the same account servicing payment service provider. This exemption is defined by the PSD2 **Article 15**.

Download the [compliance matrix](#) to access a comprehensive list of PSD2 articles, including the tools and methodology used by Feedzai to help issuers be PSD2-compliant.

3-D Secure

3-D Secure, also known as three-domain secure, is a security protocol for online credit and debit card transactions. The three domains refer to the merchant/acquirer, the issuer, and the interoperability.

TFB manages both the authentication and authorization events present in a 3-D Secure (2.0 or higher) transaction to make an approve, decline or step-up authentication recommendation in a compliant manner and with full risk context.

This means that TFB helps issuer banks to:

- Comply
- Reduce risk
- Reduce friction

How?

- Provides a compliant response with PSD2 regulation that enforces SCA to be conducted, with a number of requirements and exemptions in place.
- Provides a transaction risk assessment that enables accept/decline/step-up decisions by using numerous extra data points such as device details, IP, browser, and malware flag to reduce both friction and risk.
- Makes the decision's outcome and context available to any subsequent authorizations for the same customer, card, and event.

3-D Secure integration flow

An authentication is usually the initial stage corresponding to the 3-D Secure message.

However, issuer banks can rely on the `authorization` endpoint to make a decision on the 3-D Secure authentication event (see step 3 on the following diagram).

This means that TFB's `authorization` endpoint is in charge of producing a response that includes both a score and a recommendation:

- An approve/decline decision that considers factors such as device details, IP, browser, and malware flag for transaction risk analysis. This decision also considers the results of previous 3-D Secure challenges, if any.
- A decision on whether the transaction needs SCA (`request_sca`) based on requirements and exemptions from PSD2 articles.

The `info` endpoint (see step 7 on the following diagram) can then be invoked to update and add new information to an existing authentication such as:

- Frictionless transaction: update information on the decision so as not to challenge the transaction with SCA.
- Challenged transaction: update the authentication result, including authentication type, authentication method, etc.

TFB is able to respond to different SCA use cases within the transaction life cycle:

Authorization request with post-SCA

The issuing bank sends an authorization request. The risk engine rules then process the event and generate a recommendation. In this example, consider `sca_required = true`. The bank then asks the customer to authenticate and finally sends the authentication result via the `info` endpoint.

Authorization request with pre-SCA

Feedzai's API can receive an already authenticated transaction. TFB's `authorization` endpoint is prepared to receive the upstream authentication result (e.g. SCA result = true/false, method = biometrics/SMS/phone call). This result is taken into account by the risk engine rules.

How Feedzai's TFB helps with PSD2 compliance

TFB comes into play within the transaction risk analysis (TRA) by providing a recommendation on whether the issuer bank should request SCA. This recommendation is critical for overall fraud prevention. Note that, even though PSPs can claim the exemption for SCA, the issuer has the final decision and can turn down the request and, consequently, demand SCA.

The TFB contribution to PSD2 compliance is illustrated in the following diagram:

The recommendations generated by TFB can be summarized as follows:

- If `decision = approve`, the issuer should consider the `sca_required` outcome before actually approving the transaction. The `sca_required = true` result means that the payment is safe to be approved, but for compliance reasons the issuer should still request SCA before completing the transaction (this case is shown in the above diagram). If `sca_required=false`, the issuer can skip SCA and still be PSD2-compliant. This means that an article of the [exemption criteria](#) can be applied and the card/account holder is not prompted with SCA.
- If `decision = review` (outcome value available in transfers), the same SCA logic applies, i.e. the issuer should consider the `sca_required` outcome as the TFB recommendation to apply SCA while the transaction is being analyzed by a fraud analyst.
- If `decision = decline`, TFB recommends rejecting the transaction. If the issuer decides not to honor the TFB recommendation:
 - If `sca_required=true`, SCA must be performed to comply with PSD2.
 - If `sca_required=false`, the issuer can skip SCA and still be PSD2 compliant.

The out-of-the-box rules targeting specifically PSD2 compliance are organized into several rules projects. This rules project organization separates rules that trigger under PSD2 out-of-scope transactions from rules that trigger under the exemption criteria. Check the rules project pages for more information about this logic.

Use cases within the transaction life cycle

TFB is flexible in responding to different SCA use cases within the transaction life cycle:

- **Authorization request with post-SCA:** The issuing bank sends an authorization request. Then the risk engine rules process the event and generate a recommendation - in this example, consider `sca_required = true`. Then the bank asks the customer to authenticate, and finally, the bank sends the authentication result via the `info` endpoint.
- **Authorization request with pre-SCA:** The transaction can reach Feedzai already authenticated. The TFB's `authorization` endpoint is prepared to receive the results of the upstream authentication result (e.g. SCA result = true/false, method = biometrics/SMS/phone call). This result is taken into account by the risk engine rules.

Compliance matrix - download

PSD2 is organized into multiple chapters, and each chapter contains several articles. TFB provides a compliance matrix that maps each article to the tool and methodology used by Feedzai to help issuers to be PSD2-compliant. This matrix is available for download, allowing issuers to demonstrate to PSD2 regulators how their systems are fully compliant with this directive.

[COMPLIANCE MATRIX](#)

Fraud rate

The fraud rate identifies the fraud level of a given merchant or PSP. Issuer banks use this metric to decide whether to grant exemptions based on TRA as specified in the PSD2 mandate, Article 18 (learn more about this article by downloading the compliance matrix document).

PSD2 states that: "The overall fraud rate for each type of payment instrument should be calculated as the **total value of unauthorised or fraudulent remote transactions**, whether the funds have been recovered or not, **divided by the total value of all remote transactions for the same type of payment instrument**, whether authenticated with the application of strong customer authentication or executed under any relevant exemption in accordance with Articles 13 to 16 on a rolling quarterly basis (90 days)"

The merchants and PSPs that request a TRA exemption must have an overall fraud rate for a specific payment instrument that is equal to, or is lower than, a reference fraud rate defined in the PSD2 document.

The TFB's API specification includes the `reference_fraud_rate` field present in the [Cards](#) and [Transfers](#) data structures. This field can be populated in different ways:

- The fraud rate is directly sent by the client via the API request.
- The fraud rate is stored in a list (i.e. leveraging the TFB's risk engine platform) and is then used to populate the `reference_fraud_rate` field. This option can also have different scenarios:
 - The value is inserted directly in Pulse by Feedzai's clients.
 - The value is automatically calculated via Insights dashboards, available by default in the TFB's package.

Alerting

Even though payment service providers should cease applying the exemption if the *monitored fraud rate exceeds for two consecutive quarters the reference fraud rate applicable for that payment instrument or type of payment transaction in that exemption threshold range*, Feedzai alerts when the fraud rate exceeds any of the reference fraud rate in the following Annex table. This will allow the bank to take action and keep fraud levels low before exceeding the reference for two consecutive quarters.

ETV	Remote electronic card-based payments	Remote electronic credit transfers
EUR 500	0,01	0,005
EUR 250	0,06	0,01
EUR 100	0,13	0,015

An email will be sent when the fraud rate for a given payment instrument exceeds any of the above thresholds. The email will indicate under which scope the alert was triggered, thus allowing the payment service providers to take preemptive measures.

Learn more

Now that you know how TFB's rules help issuers to be PSD2 compliant, check the [Rules Projects](#) page for the rules provided out of the box.

You can also check the [Work with Rules and Lists](#) guide to learn how to:

- Write rules customized for your business needs.

- Configure your work in the runtime workflow.
- Test rules using the TFB API.